By Sommer Compliance Architecture

Compliance Architecture Alignment

By Sommer is a research-driven innovation studio based in Copenhagen, Denmark, specializing in machine learning (ML), large language models (LLMs), and strategic design thinking. Operating within the European Union, committed to full compliance with the General Data Protection Regulation (GDPR), the EU AI Act, the NIS2 Directive, and other relevant European legal frameworks. Compliance architecture is designed to ensure legal enforceability, ethical governance, and operational resilience - all of which are essential for Horizon Europe grant eligibility.

---

1. Legal Compliance and Risk Management

GDPR and Data Subject Rights

- We maintain comprehensive privacy policies that define the legal basis for data processing, including consent, contract performance, and legitimate interest.
- Our Data Processing Agreements (DPAs) designate By Sommer as the Processor, ensuring data is handled only under documented client instructions.
- We uphold all data subject rights: access, rectification, erasure, restriction of processing, and data portability.
- Internal protocols ensure deletion requests are fulfilled within 30 days, with financial records retained per the Danish Bookkeeping Act.

EU AI Act and General-Purpose AI (GPAI)

- We classify AI systems according to the EU AI Act's risk tiers (Minimal, Limited, High-Risk, and GPAI).
- For GPAI models, we maintain technical documentation, training data summaries, and risk management systems.
- For high-impact foundational models (e.g., exceeding 10^25 FLOPs), we prepare for systemic risk obligations, including red-teaming, incident reporting, and compliance with European AI Office requirements.

Network and Cybersecurity (NIS2)

- We implement technical, operational, and organizational measures to protect network and information systems.
- Our cybersecurity policies include risk analysis, incident response, business continuity planning, and multi-factor authentication.
- We align with NIS2 obligations for essential and important entities in the EU.

---

2. Ethical Governance, Fairness, and Accountability

Responsible AI (RAI) and Human-in-the-Loop (HITL)

- All high-stakes AI deployments require human oversight.
- Our AI & IP Addendum mandates that clients act as the final decision-makers, verifying all outputs before use.
- We prioritize augmentation over automation to ensure accountability.

Bias Mitigation and Anti-Discrimination

- We assess training datasets for bias and implement mitigation strategies.
- We reserve the right to terminate agreements if clients misuse AI for discriminatory, malicious, or unethical purposes.

Corporate Transparency and Conduct

- Our Code of Conduct prohibits unlawful, harmful, or discriminatory behavior.
- Compliance monitoring functions are embedded into our operations.

---

3. Intellectual Property and Digital Market Fairness

IP Ownership and Licensing

- Clients retain ownership of final deliverables upon payment.
- By Sommer retains all proprietary methodologies, frameworks, and source code.
- Our contracts include disclaimers regarding the copyrightability of AI-generated content.

AI Training Prohibition

- Our Website Terms of Use explicitly prohibit the use of any site content for training AI systems, ML models, or LLMs without express written consent.
- This clause protects our proprietary research and digital assets from unauthorized scraping.

Digital Market Fairness

- We comply with EU regulations targeting gatekeeper platforms, ensuring non-discrimination in data access, ranking, and interoperability.

---

4. Operationalizing Compliance

Contract Lifecycle Management

- All B2B engagements require e-signed MSA, AI & IP Addendum, and DPA before project initiation.
- These documents are integrated into our onboarding workflows via secure e-signature platforms.

Public LLM Usage Restrictions

- Staff are trained not to input client data into public LLMs (e.g., ChatGPT) unless explicitly authorized via contract.
- Enterprise-grade LLM instances are used only under strict contractual and technical safeguards.

Digital Product Compliance (Imsor.com)

- Our Subscription Agreement includes an explicit waiver of the 14-day withdrawal right for digital goods, in line with EU consumer protection law.
- Subscriptions auto-renew monthly unless canceled, and fees are non-refundable unless required by law.

---

5. Public-Facing Legal Integration

Website Legal Hub

- The global footer of bysommer.net links to the Privacy Policy, Cookie Policy, and Website Terms of Use.
- All forms include a required checkbox for affirmative consent to these policies.

Privacy Policy (By Sommer and Imsor.com)

- Enumerates GDPR rights for EEA/UK residents.
- Provides contact emails (e.g., privacy@programintegrity.org, compliant@imsor.com) for rights requests.

Terms of Use

- Asserts ownership of all site content and research methodologies.

- Prohibits use of content for AI training without written consent.

Conclusion

By Sommer's compliance architecture is designed to meet - and exceed - the legal, ethical, and operational standards required by Horizon Europe. Our integrated governance framework ensures that every AI engagement is transparent, accountable, and aligned with the EU's evolving regulatory landscape. This positions us as a trusted partner for responsible innovation and strategic transformation across the digital economy.